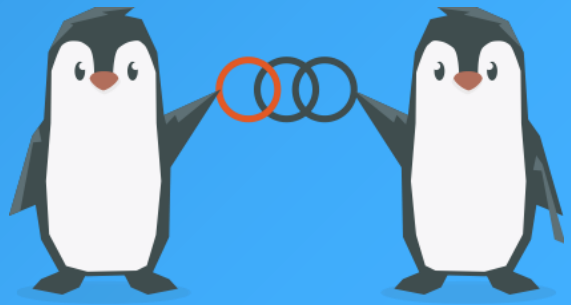
OpenChain SBOM WG

2026-10-28

THE LINUX FOUNDATION

OPENCHAIN



Anti-Trust Policy Notice

- Linux Foundation meetings involve participation by industry competitors, and it is the intention of the Linux Foundation to conduct all of its activities in accordance with applicable antitrust and competition laws. It is therefore extremely important that attendees adhere to meeting agendas, and be aware of, and not participate in, any activities that are prohibited under applicable US state, federal or foreign antitrust and competition laws.
- Examples of types of actions that are prohibited at Linux Foundation meetings and in connection with Linux Foundation activities are described in the Linux Foundation Antitrust Policy available at http://www.linuxfoundation.org/antitrust-policy/. If you have questions about these matters, please contact your company counsel, or if you are a member of the Linux Foundation, feel free to contact Andrew Updegrove of the firm of Gesmer Updegrove LLP, which provides legal counsel to the Linux Foundation.

Open Source Summit Europe 2026

Open Source for a Stronger, More Self-Reliant Europe

7-9 OCTOBER 2026 | **PRAGUE, CZECHIA**

A global gathering for an open, innovative and resilient Europe



Event Overview

Open Source Summit Europe 2026 brought together developers, companies, governments and communities from around the world. Discussions focused on AI, security and digital sovereignty, exploring how open source can build a more innovative, resilient and self-reliant Europe.

Key Highlights

- AI, security and digital sovereignty were key themes
- 2,344 attendees from around the world
- 305 sessions covering a wide range of topics
- 59 sponsors supporting the event
- Diverse participation across industries, roles and regions
- A forum to shape the future of open source in Europe

Attendance at a Glance

2,344 ATTENDEES On-site

987 ORGANIZATIONS

59 SPONSORS

Attendees by Region



Attendee Profile

68% in technical roles

Top Attendee Countries

1. USA
2. CZECHIA
3. FRANCE

Plus many other countries

Attendees by Job Function

Engineering / Software Development	49.0%
Architecture (Software / Systems)	6.2%
Executive Management	4.0%
IT Operations / Infrastructure	3.1%
Sales / Marketing / Media	2.5%
DevOps / Site Reliability Engineering	2.2%
Community Management	1.8%
Security / Compliance	1.4%
Student / Academic	1.4%
Product Management	1.4%
Education / Training / Research	1.4%
Data Science / AI / ML	1.4%
Other	10.3%

Attendees by Industry

Information Technology	45.7%
Telecommunications	13.2%
Automotive	5.6%
Energy	4.9%
Consumer Goods	4.6%
Financials	3.0%
Health Care	2.4%
Other	2.3%

Conference Scale

1,660 TALKS SUBMITTED

305 SESSIONS DELIVERED

Badge Scans (On-site)

152	519	6,840
AVERAGE SCANS PER PERSON	HIGHEST SCANS PER PERSON	TOTAL SCANS

Top Topics (Talks)

Embedded Systems	51%
AI, ML & Data Analytics	50%
Linux & System Administration	48%
DevOps, CI/CD & Site Reliability	39%
Cloud, Cloud Native & Containers	38%
Privacy, Security & Compliance	37%
Networking & Edge	31%
Leadership, Community & Governance	30%
Open Hardware	29%
Application Development & Media Tech	27%
Safety-Critical Systems	26%
Sustainability	18%
Decentralized Trust	15%

https://events.linuxfoundation.org/wp-content/uploads/2026/10/OSS-EU-26-_Post-eventReport.pdf

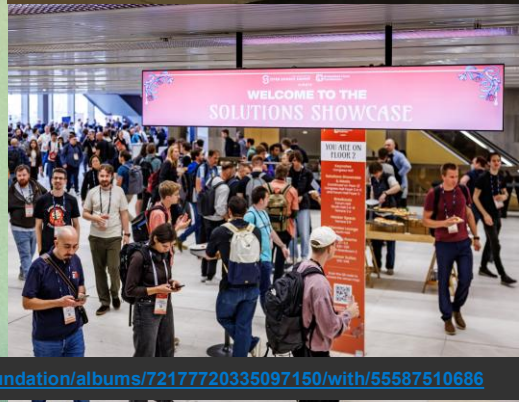












https://www.flickr.com/photos/linuxfoundation/albums/72177720335097150/with/55587510686

Operational Compliance in Open Source:
The OpenChain Business Operations

Building trust together for a brighter software future

OPENCHAIN
Open Source for a Brighter Future

Overview

This session explored operational compliance in open source, focusing on the OpenChain initiative. Speakers from industry, consulting, and the OpenChain community shared perspectives on key requirements, challenges, and practical approaches.

Key Takeaways

- Operational compliance is essential for trustworthy and sustainable open source.
- It involves security, licensing, legal and internal policies.
- Transparency is a core principle.
- The OpenChain Business Operations Study Group has produced a CRA guidance checklist.

Speakers



Mary (Meixia) Wang (OpenChain)



Ummo Schwarting (Deloitte)



Marcel Kurzmann (Bosch)

1 What is Operational Compliance?

Three pillars for trustworthy software

Security Compliance
Address vulnerabilities and security requirements

License Compliance
Proper use of open source licenses

Operational Compliance
Meet legal, internal policies and contractual obligations

Together, these pillars enable trustworthy software.

Examples of operational compliance scope

- Regulations (e.g., CRA)
- Internal policies
- Contract requirements
- Processes and governance

2 Perspectives and Key Discussion Points



Mary (Meixia) Wang (OpenChain)

Expand OpenChain across all industries

- Our goal is to bring OpenChain to more industries worldwide.
- Let's learn from each other and build compliance together.



Ummo Schwarting (Deloitte)

Compliance is interconnected

- Export controls, security, licensing and legal requirements are closely linked.
- We need practical processes and data to address these together.



Marcel Kurzmann (Bosch)

Transparency is the foundation

- License compliance has matured, but new requirements such as the CRA are emerging.
- Transparency across the supply chain is key, and SBOM is an important enabler.

3 OpenChain Initiatives

OPENCHAIN

CRA Guidance Checklist
The OpenChain Business Operations Study Group has published a checklist to support the EU Cyber Resilience Act (CRA).

4 Next Steps (Session Flow)

First 15 min
Speakers' presentations

Next 15 min
Q&A and discussion

Final
Key takeaways and outlook

Toward a Sustainable Open Source Ecosystem

Let's continue working together across industry, companies and communities to advance operational compliance and a brighter software future.

https://todogroup.org/blog/2026-10-19-openchain-ospology-prague-2026-recap/

Breakout Session: Community led-discussion

Key topics on SBOM standards, data management, security, AI, and open source discussed by the community.

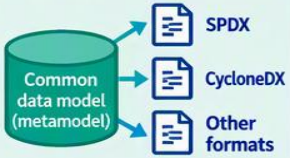
1 Migration of SBOM Standards and Formats

Migration from older versions of SPDX and CycloneDX to newer versions is delayed, with implementation and compatibility being key challenges.



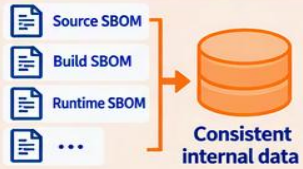
2 From File Formats to a Common Metamodel

Rather than focusing on differences between file formats, establish a common data model (metamodel) and generate the required SBOM formats from the same data.



3 Handling Supplier SBOMs

How to integrate SBOMs from suppliers (source, build, runtime, etc.) and manage and verify them as consistent internal data.



4 SBOM and Call Graphs for Security

It's not enough to know whether a vulnerability exists. We also need to understand whether vulnerable code is actually called and reachable in practice.



5 Long-term Data Preservation and Traceability

Keep critical software information in-house, without relying solely on external services, to ensure long-term product support and regulatory compliance.



6 AI for Code Analysis and Reimplementation

AI can accelerate development work, but human expertise remains essential to understand the intent and behavior of code.



7 Trust, Ethics, and Reimplementation in Open Source

Discussions covered code reimplementation, licenses, and consideration for original authors and maintainers, and how to think about "trust" in the software supply chain.



8 Maintainer Workload and AI-generated Contributions

A large number of AI-generated pull requests may create excessive workload for maintainers with limited resources.



9 SBOM and Standardization for AI

Whether existing standards can address AI-related challenges or new standards are needed, and how to represent and verify AI-generated code, was discussed.



- Use existing standards or new ones?
- How to represent AI-generated code?
- How to verify and display the information?

Key Takeaways

- Address the gaps between standard evolution and real-world implementation.
- Ensure consistent data management and traceability.
- Balance the opportunities and risks of AI while building a trusted software supply chain.



The FOSEDM dev room has been announced. However, unfortunately, **the SBOM devroom was not accepted this year**.
There will be a devroom focused on the CRA instead, and that topics such as SBOMs will likely be discussed there.
- Beyond the CRA - Building Secure and Resilient Open Source

THE LINUX FOUNDATION OPENCHAIN



Philippe Ombredanne · 1次
On a mission to make open source easy and safe to ...
8分

On Friday, January 29th 2027, the day before **#FOSDEM** what is the place to be?
Brussels, Belgium at **#FOSSApalooza** a new FOSDEM "fringe"event, co-organized by the **OWASP® Foundation**, the **Open Regulatory Compliance** group, the **OpenChain Project** and the **AboutCode Foundation**
(Note: this year, the AboutCode workshop will take place on Monday, the day after FOSDEM)
#cybersecurity #cra #opensource #license #foss #compliance #security

1

FOSS apalooza
29 JANUARY 2027
BRUSSELS
An open source conference the day before FOSDEM

https://fossapalooza.eu/

https://lnkd.in/p/gHYZH-5U

THE LINUX FOUNDATION
OPENCHAIN



https://techcommunity.microsoft.com/blog/windows-hardware-certification/sbom-requirements-for-applicable-driver-submissions-beginning-with-the-windows-r/4566674

